

# API Security Risk Analysis Report

By: Praveena Nagaraju  
Date: February 19, 2026

## Table of Contents

|                        |   |
|------------------------|---|
| API Tested.....        | 1 |
| Identified Risks ..... | 1 |
| Business Impact .....  | 2 |
| Recommendations.....   | 3 |

## API Tested

- **Target:** Public demo API (e.g., Swagger Petstore API)
- **Scope:** Read-only inspection of endpoints, headers, authentication, and response behavior.
- **Methodology:** Documentation review, safe GET requests, and response analysis.

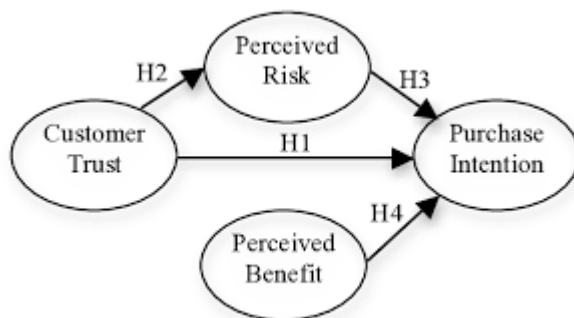
## Identified Risks

| Risk Category                  | Description                                                                                             | Severity | Business Impact                                                  | Remediation                                                                     |
|--------------------------------|---------------------------------------------------------------------------------------------------------|----------|------------------------------------------------------------------|---------------------------------------------------------------------------------|
| <b>Authentication Gaps</b>     | Some endpoints allow unauthenticated access to sensitive operations (e.g., viewing user or order data). | High     | Attackers can bypass login and directly query sensitive data.    | Enforce authentication on all endpoints; use OAuth2 or JWT-based access tokens. |
| <b>Excessive Data Exposure</b> | API responses return full objects with unnecessary fields (e.g., internal IDs, metadata).               | Medium   | Increases risk of data leakage and reconnaissance for attackers. | Implement response filtering; return only required fields.                      |
| <b>Rate Limiting Absent</b>    | No throttling or quota                                                                                  | High     | Attackers can overload                                           | Apply rate limiting (e.g.,                                                      |

|                                       |                                                             |        |                                                          |                                                                       |
|---------------------------------------|-------------------------------------------------------------|--------|----------------------------------------------------------|-----------------------------------------------------------------------|
|                                       | enforcement observed.                                       |        | systems with automated requests (DoS or brute force).    | API Gateway, WAF rules).                                              |
| <b>Error Handling Weakness</b>        | Error messages reveal stack traces or internal logic.       | Medium | Provides attackers with insights into backend structure. | Replace verbose errors with generic messages; log details internally. |
| <b>Lack of Encryption Enforcement</b> | API accessible over plain HTTP in addition to HTTPS.        | High   | Exposes sensitive data to interception (MITM attacks).   | Force HTTPS; redirect HTTP requests to secure endpoints.              |
| <b>CORS Misconfiguration</b>          | Wide-open CORS policy (Access-Control-Allow-Origin: *).     | Medium | Allows malicious websites to interact with API directly. | Restrict CORS to trusted domains.                                     |
| <b>Inconsistent Input Validation</b>  | Some endpoints accept arbitrary strings without validation. | Medium | Risk of injection attacks or malformed data storage.     | Apply strict schema validation (JSON schema, parameter sanitization). |

## Business Impact

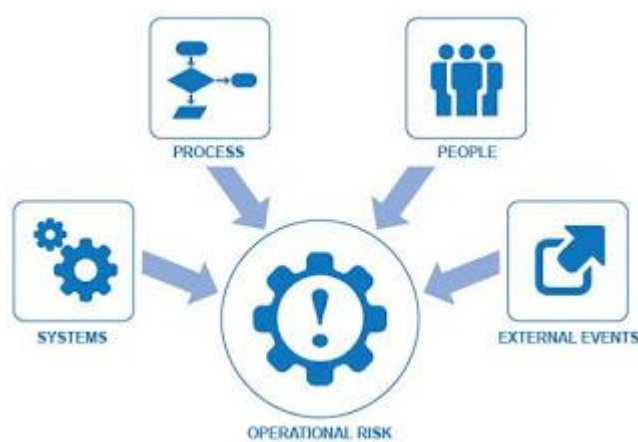
- **Customer Trust Risk:** If attackers access or leak sensitive data, customers lose confidence in the platform.



- **Compliance Risk:** Unsecured APIs may violate GDPR, HIPAA, or PCI-DSS requirements.



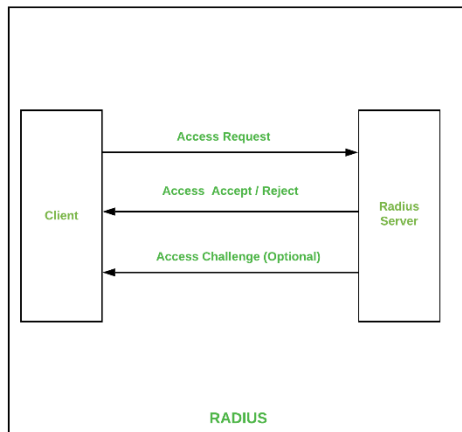
- **Operational Risk:** Lack of rate limiting can lead to downtime, affecting revenue and SLAs.



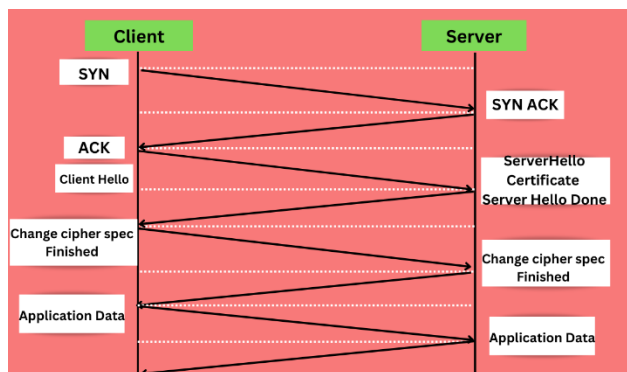
- **Reputation Risk:** Public breaches damage brand reputation and investor confidence.

## Recommendations

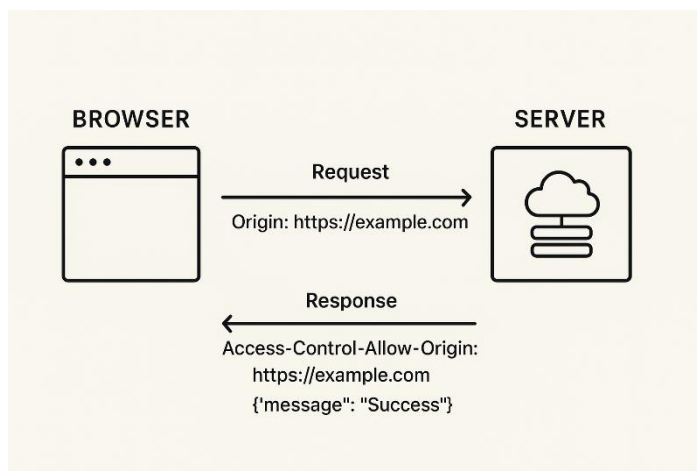
- **Authentication & Authorization:** Require strong token-based authentication for all endpoints.



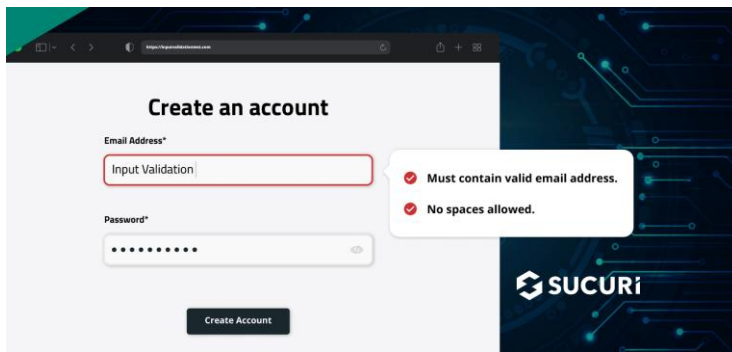
- **Data Minimization:** Return only necessary fields in API responses.
- **Rate Limiting & Monitoring:** Implement quotas, throttling, and anomaly detection.
- **Secure Error Handling:** Show generic error messages; log details internally.
- **Transport Security:** Enforce HTTPS with TLS 1.2+; disable insecure protocols.



- **CORS Hardening:** Restrict origins to trusted domains.



- **Input Validation:** Use strict schemas and sanitize all inputs.



The screenshot shows a web browser window displaying the 'Create an account' page of a Sucuri website. The page has a dark blue header with the Sucuri logo and a circuit-like pattern. The main content area is white and contains two input fields: 'Email Address\*' and 'Password\*'. The 'Email Address\*' field is highlighted with a red border and contains the text 'Input Validation'. A white tooltip box with a red border is positioned to the right of the email field, containing two error messages: 'Must contain valid email address.' and 'No spaces allowed.', each preceded by a red checkmark icon. The 'Password\*' field is a standard password input with a red border and a toggle icon on the right. Below the password field is a 'Create Account' button. The background of the page features a dark blue pattern with circuit lines and dots.

- **Regular Security Audits:** Schedule penetration testing and automated scans.